

OWASP TOP 10 (2021) SUMMARY REPORT

Comprehensive Synthesis, Security Analysis & DVWA Vulnerability Mapping

Document Type: Technical Security Report
Focus Area: OWASP Top 10 Security Risks & Practical Exploitation

Document Type: Technical Security Report
Focus Area: OWASP Top 10 Security Risks & Practical Exploitation

1. Executive Summary

The OWASP Top 10 represents a globally recognized standard for web application security awareness. Updated periodically based on broad industry data, vulnerability telemetry, and security research, the 2021 list reflects structural shifts toward root-cause architectural weaknesses, insecure design patterns, and systemic supply chain vulnerabilities.

This technical summary report provides an original synthesized breakdown of all ten security risks from the 2021 OWASP release. It further connects theoretical concepts to practical hands-on execution through precise mapping to the Damn Vulnerable Web Application (DVWA), complete with annotated demonstration screenshots and actionable remediation guidelines.

❑ **Key Insight: Shift from Symptoms to Root Causes**

The 2021 OWASP Top 10 marked a pivotal evolution. Security priorities moved from superficial code bug detection toward structural architecture (A04: Insecure Design), access control enforcement (A01: Broken Access Control), and supply chain visibility (A06: Vulnerable and Outdated Components).

2. OWASP Top 10 (2021) Master Overview

OWASP ID	Vulnerability Category Name	Primary Risk Focus
A01:2021	Broken Access Control	Authorization enforcement failure, privilege escalation, unauthorized data read/write.
A02:2021	Cryptographic Failures	Exposure of sensitive data due to weak

		encryption, plaintext storage, or key misuse.
A03:2021	Injection	Untrusted data sent to an interpreter resulting in unauthorized query/command execution.
A04:2021	Insecure Design	Flaws in architecture, threat modeling, and business logic prior to code implementation.
A05:2021	Security Misconfiguration	Unsecured default settings, overly permissive HTTP headers, open cloud storage.
A06:2021	Vulnerable & Outdated Components	Risks arising from third-party libraries, framework dependencies, and unpatched code.
A07:2021	Identification & Authentication Failures	Weak password policies, broken session management, lack of multi-factor authentication.
A08:2021	Software & Data Integrity Failures	Violations in auto-updates, CI/CD pipelines, or untrusted deserialization.
A09:2021	Security Logging & Monitoring Failures	Insufficient log depth, lack of real-time alerts, delayed incident response.
A10:2021	Server-Side Request Forgery (SSRF)	Applications fetching remote resources without validating user-supplied URLs.

3. OWASP Top 10 Detailed Analysis & DVWA Mappings

A01:2021 - Broken Access Control

Broken Access Control moved up to the #1 spot in the OWASP Top 10. Access control enforces policies so users cannot act outside their intended permissions. Failures lead to unauthorized information disclosure, modification, or destruction of all data, or performing a business function outside the user's limits.

- DVWA Mapping & Hands-on Exploitation:

In DVWA, this category is prominently illustrated through the File Inclusion and Directory Traversal vulnerabilities, where an attacker modifies URL parameters (e.g., `?page=../../../../etc/passwd`) to bypass access controls and access sensitive system files.

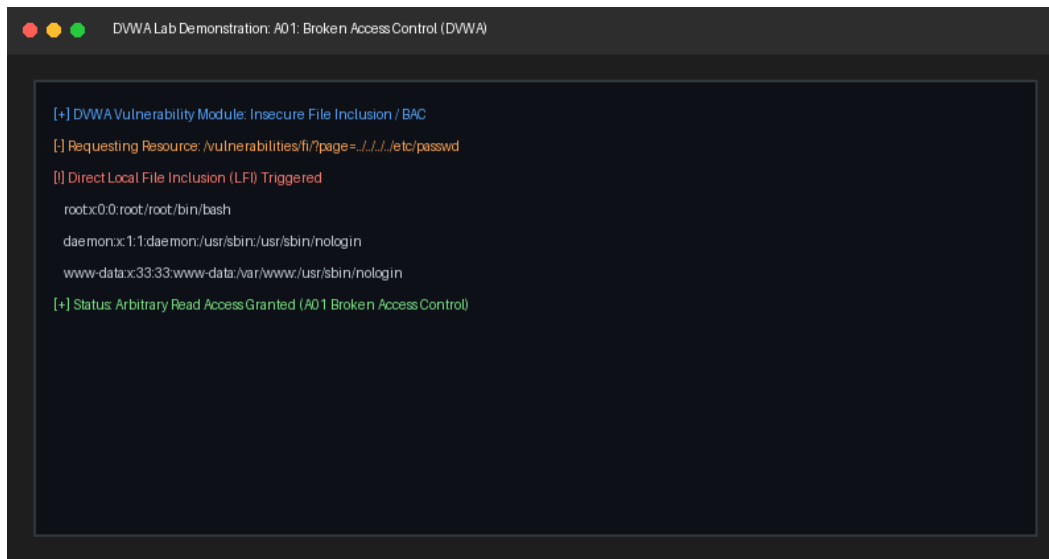


Figure 1: Demonstration of Broken Access Control (Directory Traversal / LFI) in DVWA.

A02:2021 - Cryptographic Failures

Formerly known as Sensitive Data Exposure, this risk focuses on failures related to cryptography (or lack thereof), which frequently leads to sensitive data exposure. Key factors include transmitting cleartext sensitive data (HTTP, FTP), using outdated algorithm implementations (MD5, SHA1), or failing to enforce proper password hashing algorithms (e.g., Argon2, bcrypt).

- DVWA Mapping:

In DVWA, storing passwords using simple MD5 hashes or transmitting session cookies over plain unencrypted HTTP demonstrates classic cryptographic vulnerabilities that allow attackers to intercept traffic or break hashes easily.

A03:2021 - Injection

Injection encompasses SQL, Command, NoSQL, and ORM injection, as well as Cross-Site Scripting (XSS). Injection occurs when untrusted user input is directly concatenated into dynamic queries or interpreter calls without input validation or parameterized queries.

- DVWA Mapping & Hands-on Exploitation:

DVWA provides full modules dedicated to SQL Injection, Blind SQL Injection, Command Injection, and Stored/Reflected XSS. Below are practical demonstrations of both SQL Injection and Stored XSS modules in DVWA.

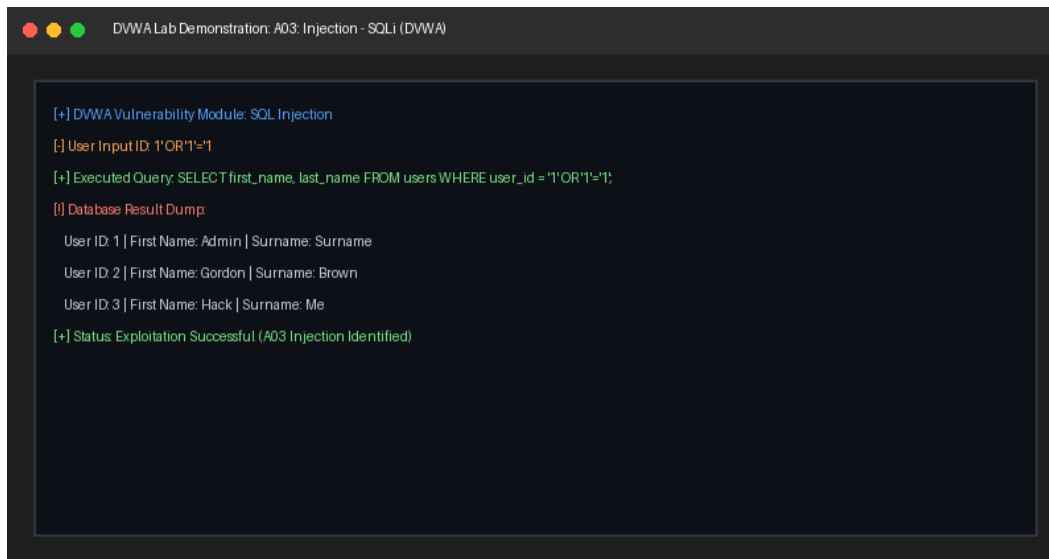


Figure 2: SQL Injection exploitation in DVWA dumping the user database table.

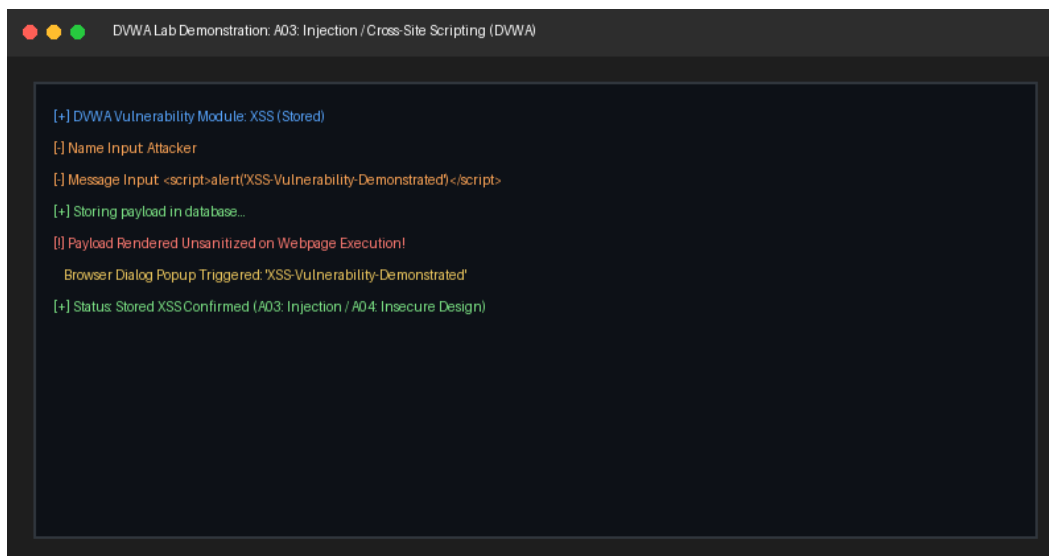


Figure 3: Stored Cross-Site Scripting (XSS) payload execution in DVWA guestbook module.

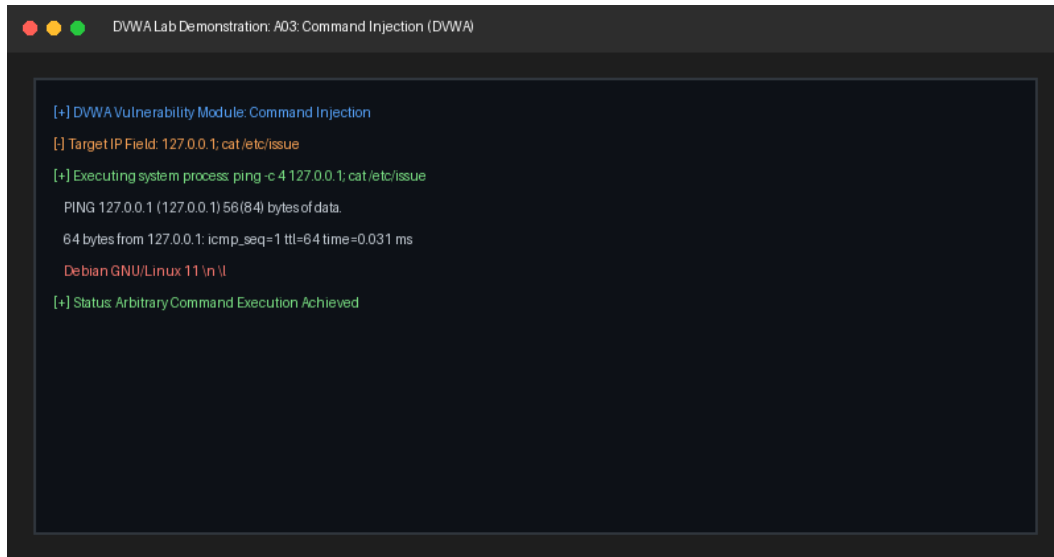


Figure 4: Operating System Command Injection in DVWA Ping feature.

A04:2021 - Insecure Design

A new category for 2021 focusing on risks related to design and architectural flaws. Insecure design cannot be fixed by perfect implementation or code fixes alone; it requires threat modeling, secure design patterns, and reference architectures.

- DVWA Mapping:

DVWA demonstrates insecure design through business logic flaws, such as missing CSRF token verification on state-changing operations across low and medium security levels.

A05:2021 - Security Misconfiguration

This category involves unpatched flaw exploitation, enabling unnecessary features, default accounts/passwords left intact, detailed error messages revealing stack traces, and improper server header configurations.

- DVWA Mapping:

DVWA itself relies on a misconfigured environment setup by default (e.g., displaying verbose PHP error reporting and allow_url_include enabled in php.ini).

A06:2021 - Vulnerable and Outdated Components

Using third-party libraries, frameworks, or software modules with known vulnerabilities exposes applications to severe risk. Attackers actively exploit published CVEs in unpatched web application dependencies.

A07:2021 - Identification and Authentication Failures

Previously called Broken Authentication, this risk encompasses weaknesses in confirmation of user identity, session management, and credential protection (e.g., credential stuffing attacks, weak password rules, missing MFA, linear session identifiers).

- DVWA Mapping & Hands-on Exploitation:

In DVWA, the Brute Force module exemplifies authentication failures where rate limiting and account lockout mechanisms are completely absent.

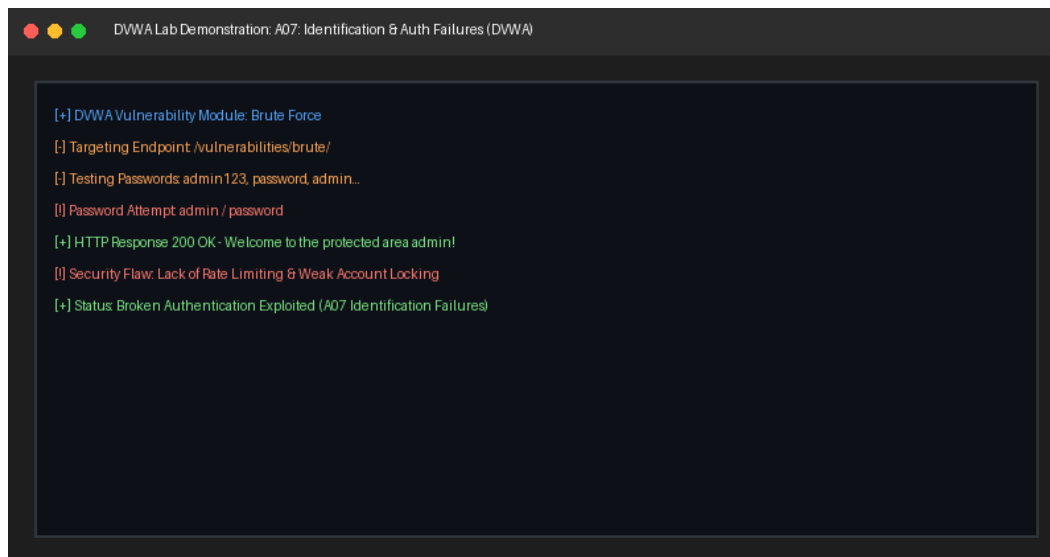


Figure 5: Automated brute force attack against DVWA authentication endpoint.

A08:2021 - Software and Data Integrity Failures

Focuses on making assumptions regarding code updates, critical data, and CI/CD pipelines without verifying integrity. A key sub-type is unsafe insecure deserialization, where remote objects are executed without validation.

A09:2021 - Security Logging and Monitoring Failures

Without adequate logging, auditing, and real-time alert monitoring, security breaches cannot be detected or contained in a timely manner. The average time to detect a breach often exceeds 200 days due to logging failures.

A10:2021 - Server-Side Request Forgery (SSRF)

SSRF vulnerabilities occur whenever a web application fetches a remote resource without validating the user-supplied URL. Attackers force the web server to send crafted HTTP requests to internal, firewalled systems.

4. Summary Mapping Table: OWASP vs. DVWA Modules

OWASP Top 10 Category	DVWA Module / Mechanism	Practical Exploit Summary
A01: Broken Access Control	File Inclusion / Directory Traversal	Local/Remote File Inclusion allowing read access to /etc/passwd.
A02: Cryptographic Failures	Insecure Cookie / Weak Hash Storage	Cleartext password transmission and simple MD5 hash usage.
A03: Injection	SQLi, Command Injection, Stored/Reflected XSS	Bypassing SQL parameters, executing shell ping commands, script injection.
A04: Insecure Design	CSRF / Logic Flaws	State changing requests lacking cryptographic anti-CSRF tokens.
A05: Security Misconfiguration	PHP / Environment Configuration	Verbose error messages, open permissions, and debug flags enabled.
A06: Outdated Components	Obsolete PHP Libraries	Using unpatched legacy server engines and frameworks.
A07: Identification Failures	Brute Force Module	Unrestricted attempt rates on login forms with simple wordlists.
A08: Integrity Failures	Unverified File Uploads	Uploading arbitrary PHP scripts without header or payload validation.
A09: Logging Failures	System Audit Absence	Lack of audit logs capturing automated brute-force or injection sweeps.
A10: SSRF	Custom URL Fetcher / Webhooks	Forcing web server to query internal localhost services.

5. Practical Remediation & Defensive Best Practices

To mitigate the vulnerabilities outlined in the OWASP Top 10 and demonstrated in DVWA, organizations should implement defense-in-depth measures across the development lifecycle:

- 1. Parameterized Queries:** Implement parameterized queries (prepared statements) or ORM frameworks to separate untrusted user inputs from SQL logic entirely.
- 2. Enforce Server-Side Authorization:** Enforce strict role-based access control (RBAC) at the server layer rather than relying on client-side restrictions or hidden fields.
- 3. Context-Aware Output Encoding:** Enforce context-aware output encoding (HTML, JavaScript, CSS) and robust Content Security Policy (CSP) headers.

4. **Robust Authentication Controls:** Mandate strong multi-factor authentication (MFA), account logout triggers, and strict rate-limiting on sensitive endpoints.
5. **CI/CD Security Automation:** Establish automated Dependency-Check, SAST, and DAST scans in CI/CD pipelines to catch vulnerabilities prior to release.

Share your win with your peers

Your progress can inspire others in your community.



OWASP Top 10 2025: Insecure Data Handling completed!

neharehan2020 completed another room on their cyber security journey.

Completed tasks

4

Points earned

24

Streak

6

Share on social media

Share your win before starting the next room

LinkedIn

WhatsApp

Telegram

Twitter / X

Facebook

Reddit

Go to dashboard

OWASP Top 10:2025

Search

OWASP/Top10

OWASP Top 10:2025

Home

Introduction

About OWASP

What are Application Security Risks?

Establishing a Modern Application Security Program

Top 10:2025 List

A01 Broken Access Control

A02 Security Misconfiguration

A03 Software Supply Chain Failures

A04 Cryptographic Failures

A05 Injection

A06 Insecure Design

A07 Authentication Failures

A08 Software or Data Integrity Failures

A01:2025 Broken Access Control

Background.

Maintaining its position at #1 in the Top Ten, 100% of the applications tested were found to have some form of broken access control. Notable CWEs included are *CWE-200: Exposure of Sensitive Information to an Unauthorized Actor*, *CWE-201: Exposure of Sensitive Information Through Sent Data*, *CWE-918 Server-Side Request Forgery (SSRF)*, and *CWE-352: Cross-Site Request Forgery (CSRF)*. This category has the highest number of occurrences in the contributed data, and second highest number of related CVEs.

Score table.

CWEs Mapped	Max Incidence Rate	Avg Incidence Rate	Max Coverage	Avg Coverage	Avg Weighted Exploit	Avg Weighted Impact	Total Occurrences
40	20.15%	3.74%	100.00%	42.93%	7.04	3.84	1,839,701

Table of contents

Background.

Score table.

Description.

How to prevent.

Example attack scenarios.

References.

List of Mapped CWEs